

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14 COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

NAME :KOTA PUJITHA

REG NO:192311124

CO4: Implement network security testing methods by performing web server attacks, analyzing web

application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)

Assessment Tool Weightage: 35%

QUESTIONS: 5

Total Marks:100

1. Security Assessment of an E-Commerce Web Application

Introduction

The e-commerce company is experiencing unauthorized transactions and abnormal account activity. The investigation has identified suspicious HTTP requests, attempts to access hidden directories, malicious scripts submitted through input fields, and an outdated Apache server. The absence of a Web Application Firewall (WAF) further increases the attack surface.

The major possible attack vectors are:

- Outdated Apache/web-server vulnerabilities
- Directory and file enumeration
- SQL Injection
- Cross-Site Scripting (XSS)
- Weak input validation
- Weak authentication and session management
- Insecure server configuration
- Missing WAF and intrusion detection
- Vulnerable third-party software components

Reconnaissance

Reconnaissance is the first phase of a security assessment. It is performed only against systems for which authorization has been obtained.

Kali Linux tools that can be used include:

Nmap: Used to identify open ports and running services.

```
nmap -sV -sC <AUTHORIZED-TARGET>
```

The result can identify services such as HTTP/HTTPS and provide information about the web-server version.

WhatWeb: Used to identify web technologies.

```
whatweb http://<AUTHORIZED-TARGET>
```

Nikto: Can identify common web-server configuration problems and potentially dangerous files.

```
nikto -h http://<AUTHORIZED-TARGET>
```

Directory discovery can be performed in an isolated assessment environment using tools such as Gobuster:

```
gobuster dir -u http://<AUTHORIZED-TARGET> -w <AUTHORIZED-WORDLIST>
```

The assessment should look for exposed administration pages, backup files, configuration files, forgotten directories, and other unnecessary resources.

Vulnerability Scanning

The discovered Apache version should be compared against the vendor's security advisories and vulnerability databases. Tools such as Nmap, Nikto, and OpenVAS/Greenbone can assist with vulnerability identification.

The analyst should determine:

1. Apache version
2. Operating-system version
3. Enabled modules
4. TLS configuration
5. Exposed services
6. Vulnerable libraries
7. Missing security patches
8. Insecure configuration settings

Input Validation Assessment

The application's input fields should be tested in a controlled environment for:

- SQL injection

- XSS
- Command injection
- Path traversal
- File-upload vulnerabilities
- Improper authentication
- Parameter tampering

Burp Suite can intercept requests and allow the analyst to examine how user input is transmitted and processed.

For example, a harmless test string can be entered into an authorized test application:

```
<script>alert("XSS-Test")</script>
```

If the application returns the input without appropriate encoding, it may indicate a potential XSS vulnerability. Testing should be performed with non-destructive payloads and never against third-party systems without permission.

Exploitation Validation

Exploitation should be performed only in an authorized laboratory or staging environment. The objective should be to demonstrate the vulnerability without stealing data, modifying production records, or disrupting services.

Burp Suite can be used to:

1. Intercept an HTTP request.
2. Identify parameters accepting user input.
3. Send the request to Repeater.
4. Modify one parameter at a time.
5. Observe the server response.
6. Determine whether the input is properly validated or encoded.

For SQL injection assessment, SQLmap can be used against an explicitly authorized test target to validate a suspected injection point. A safe assessment should begin with low-impact detection rather than attempting database extraction.

Layered Defense Strategy

Server Hardening

- Upgrade Apache and the operating system.
- Remove unnecessary services and modules.
- Disable directory listing.
- Apply least-privilege permissions.

- Protect configuration and backup files.
- Disable unnecessary HTTP methods.
- Configure secure TLS.
- Maintain regular security patches.

Secure Coding

- Use parameterized SQL queries.
- Validate input on the server side.
- Apply allow-list validation where possible.
- Encode output according to its context.
- Implement secure file-upload controls.
- Use secure authentication and session management.
- Store passwords using strong password-hashing algorithms.

Network Protection

- Deploy a WAF.
- Use IDS/IPS.
- Segment the web server from database servers.
- Restrict management interfaces.
- Apply firewall rules.
- Monitor HTTP access and authentication logs.
- Implement centralized security monitoring.

Conclusion

The incident is most likely the result of multiple weaknesses rather than a single vulnerability. Patching the Apache server, strengthening input validation, deploying a WAF, improving authentication, and implementing network segmentation would substantially reduce the attack surface.

2. Security Audit of a Financial Web Application

Introduction

The financial application contains SQL Injection and XSS vulnerabilities. These weaknesses are particularly serious because the application handles confidential customer and financial information. Detailed database errors also provide attackers with information about the application's internal architecture.

SQL Injection

SQL injection occurs when untrusted user input is incorporated into SQL statements without appropriate parameterization.

For example, an insecure application might conceptually construct:

```
SELECT * FROM users WHERE username = '<user_input>';
```

If the input is directly concatenated into the query, an attacker may manipulate the SQL statement.

Assessment Methodology

1. Identify login, search, transaction, and account-related parameters.
2. Use Burp Suite Proxy to intercept application requests.
3. Send suspicious requests to Burp Repeater.
4. Modify one parameter at a time.
5. Compare normal and abnormal responses.
6. Look for database errors or unexpected response behavior.
7. Confirm the issue using a harmless test case.
8. Document the affected endpoint and parameter.
9. Avoid extracting real customer information.

SQLmap may be used in an authorized lab to automate detection of suspected SQL injection points. The tester should use the least intrusive settings necessary and avoid destructive actions.

Cross-Site Scripting

XSS occurs when attacker-controlled content is returned to a user's browser without appropriate output encoding.

Types include:

- Stored XSS
- Reflected XSS
- DOM-based XSS

In this case, stored XSS is particularly dangerous if malicious content is stored in a database and subsequently displayed to other users.

XSS Testing with Burp Suite

The methodology is:

1. Identify input fields.

2. Submit a harmless XSS test string.
3. Intercept the request using Burp Suite.
4. Determine where the input is reflected.
5. Inspect the resulting HTML response.
6. Verify whether the browser interprets the input as markup or executable script.
7. Determine whether the behavior is reflected or stored.
8. Record the affected page and parameter.

Testing should use non-destructive proof-of-concept strings rather than attempting to steal cookies or credentials.

Information Disclosure

Detailed database errors can expose:

- Database type
- Table names
- Column names
- SQL statements
- File paths
- Framework information
- Application configuration details

Production applications should therefore display generic error messages while recording detailed errors securely on the server.

CIA Triad Impact

Confidentiality

SQL injection can expose:

- Customer records
- Account information
- Authentication information
- Transaction data

XSS can expose information available to users through their browser sessions if session protections are inadequate.

Integrity

Attackers may manipulate application data, modify records, or influence transactions if appropriate authorization controls are missing.

Availability

Poorly protected database queries or malicious requests may consume excessive server/database resources and potentially affect application availability.

Mitigation

SQL Injection Prevention

Use parameterized queries:

Prepared statement



Parameter value



Database

Never construct SQL queries by directly concatenating untrusted input.

XSS Prevention

- Apply contextual output encoding.
- Validate input.
- Use safe templating frameworks.
- Implement Content Security Policy.
- Avoid dangerous DOM operations.
- Sanitize HTML when HTML input is genuinely required.

Session Security

- Use Secure cookies.
- Use HttpOnly cookies.
- Use SameSite protection.
- Regenerate session identifiers after authentication.
- Implement session expiration.
- Invalidate sessions after logout.
- Use strong authorization checks for every sensitive operation.

Additional Controls

- WAF
- IDS/IPS
- Multi-factor authentication

- Secure logging
 - Vulnerability scanning
 - Regular penetration testing
 - Database least privilege
 - Secrets management
 - Security monitoring
-

3. Evil Twin Attack Against a Corporate WPA2-PSK Network

Introduction

An Evil Twin attack occurs when an attacker creates a fraudulent wireless access point that imitates a legitimate network. Users may unknowingly connect to the malicious access point, allowing the attacker to perform credential-harvesting or traffic interception attempts.

Attack Process

A typical attack chain is:

Employee



Sees familiar SSID



Connects to rogue access point



Attacker-controlled network



Fake authentication/login page



Credentials potentially exposed

The attacker may use a similar SSID, stronger apparent signal, or social engineering to encourage users to connect.

WPA2-PSK alone does not guarantee that users are connecting to the legitimate access point. Weak or shared PSKs also increase risk.

Detection Using Aircrack-ng

Aircrack-ng tools can be used by authorized wireless-security teams to observe wireless networks and identify suspicious characteristics.

The assessment can compare:

- SSID
- BSSID/MAC address
- Channel
- Signal strength
- Encryption type
- Authentication method
- Multiple APs using the same SSID

The objective is to identify unauthorized access points rather than attack legitimate networks.

Wireshark Analysis

Wireshark can capture and analyze authorized wireless traffic.

The analyst can examine:

- Beacon frames
- Probe requests/responses
- Authentication events
- Association events
- DHCP activity
- DNS traffic
- TLS connections
- Repeated authentication failures

A suspicious AP may have an unexpected BSSID, unusual channel, different security configuration, or abnormal traffic pattern.

Weaknesses in Existing Configuration

The organization has several weaknesses:

1. WPA2-PSK uses a shared credential.
2. Employees may not verify the legitimate AP.
3. Rogue AP detection may be absent.
4. Network monitoring is insufficient.
5. Users may be vulnerable to fake login pages.
6. Enterprise authentication is not being used.
7. Wireless and internal resources may not be adequately segmented.

Countermeasures

Strong Authentication

Move from shared WPA2-PSK toward WPA2-Enterprise or WPA3-Enterprise using 802.1X authentication.

Where appropriate, use certificate-based authentication such as EAP-TLS.

Wireless Monitoring

Deploy Wireless Intrusion Detection/Prevention Systems to identify:

- Rogue APs
- Evil Twins
- Unauthorized clients
- Suspicious wireless behavior
- Authentication anomalies

Network Segmentation

Separate:

Employee Wi-Fi



Corporate resources

Guest Wi-Fi



Internet only

Guest users should not have direct access to internal corporate systems.

User Awareness

Employees should be trained to:

- Verify the expected wireless network.
- Report unusual login pages.
- Avoid entering corporate credentials into suspicious pages.
- Report unexpected certificate warnings.
- Use approved VPN/security mechanisms where required.

4. Full Penetration Testing Assessment of a Wireless Employee System

Introduction

This scenario represents a chained attack in which the attacker first compromises weak wireless security and then exploits weaknesses in a web application.

The attack chain can be represented as:

Weak Wi-Fi Password



Unauthorized Network Access



Network Reconnaissance



Web Server Discovery



Web Application Enumeration



Authentication Weakness



Session Exploitation



Privilege Escalation



Confidential Employee Data

Phase 1 – Wireless Reconnaissance

The security team first identifies authorized wireless networks and records:

- SSID
- BSSID
- Channel
- Encryption
- Signal strength
- Authorized access points

Aircrack-ng tools can be used in a controlled assessment to observe wireless networks.

The objective is to determine whether weak authentication or unauthorized access points exist.

Phase 2 – Network Reconnaissance

Once authorized access to the test network has been obtained, Nmap can identify hosts and services:

```
nmap -sV -sC <AUTHORIZED-IP>
```

The assessment identifies:

- Web servers
- DNS services
- SSH services
- Database services
- Other exposed services

Only authorized systems should be scanned.

Phase 3 – Web Application Enumeration

The tester identifies:

- Login pages
- Employee-management functions
- Administrative pages
- APIs
- Session mechanisms
- Input parameters
- File-upload functionality

Burp Suite is useful for intercepting and analyzing HTTP/HTTPS requests.

Phase 4 – Vulnerability Assessment

Potential weaknesses include:

- Weak passwords
- Missing account lockout
- Broken authentication
- Session fixation
- Predictable session identifiers
- Missing authorization checks

- SQL injection
- XSS
- IDOR
- Privilege-escalation weaknesses

The tester validates vulnerabilities using harmless proof-of-concept tests.

Phase 5 – Privilege Escalation

Privilege escalation occurs when a low-privileged user gains access to functions intended for a higher-privileged user.

For example:

Employee Account



Normal User



Unauthorized Administrative Function



Administrative Data

The assessment should test authorization by using separate test accounts with different privilege levels.

A user should never be able to access an administrative resource simply by changing a URL, parameter, or client-side value.

Defense-in-Depth Framework

Wireless Security

- WPA3-Enterprise or WPA2-Enterprise
- 802.1X authentication
- Strong identity management
- Rogue AP detection
- Wireless monitoring
- Separate guest network
- Network segmentation

Web Security

- Strong authentication

- MFA for privileged users
- Secure session cookies
- Session expiration
- Server-side authorization
- Parameterized queries
- Output encoding
- CSRF protection
- Security headers

Network Security

- Firewalls
- VLAN segmentation
- IDS/IPS
- Network access control
- Continuous monitoring
- Least-privilege network access

Monitoring

Centralized logging should record:

- Authentication attempts
- Failed logins
- Privilege changes
- Administrative actions
- Suspicious network activity
- Web application errors

5. Wireless Deauthentication Attack and Defensive Assessment

Introduction

A deauthentication attack abuses weaknesses in traditional wireless management-frame protection. Attackers can cause clients to disconnect from an access point repeatedly, resulting in a denial-of-service condition.

The main impact is on **availability**.

How the Attack Works

A simplified attack sequence is:

Client $\longleftrightarrow$ Access Point

↑

|

Unauthorized management frames

|

Attacker

When a client receives a valid-looking deauthentication management frame, it may disconnect from the wireless network.

Repeated events can cause:

Repeated Disconnect

↓

Automatic Reconnection

↓

Another Disconnect

↓

Network Unavailable

This can prevent employees or students from accessing network resources.

Controlled Simulation

A security team can reproduce the behavior in an isolated laboratory using authorized equipment.

Kali Linux and Aircrack-ng can be used to observe wireless management frames and study how clients respond.

The experiment should use:

- A dedicated test access point
- Test devices
- An isolated network
- No production SSIDs
- No third-party devices

The purpose is to understand and detect the attack rather than disrupt a real network.

Wireshark Analysis

Wireshark can help identify:

- Authentication frames
- Association frames
- Deauthentication frames
- Disassociation frames
- Repeated connection attempts
- Unusual management-frame activity

A large number of deauthentication events over a short period can indicate a possible wireless denial-of-service attack.

Impact

Availability

Legitimate users repeatedly lose network connectivity.

Productivity

Students or employees may be unable to:

- Access online applications
- Attend online meetings
- Access cloud services
- Submit assignments
- Use internal systems

Security Impact

Repeated disruption may also be used as a distraction for other attacks.

Mitigation

Protected Management Frames

Use WPA3 and enable Protected Management Frames (PMF/802.11w) where supported.

PMF makes it significantly harder for unauthorized parties to forge protected management traffic.

Wireless IDS/IPS

Deploy wireless monitoring to detect:

- High volumes of deauthentication frames
- Rogue APs
- Unusual BSSIDs

- Suspicious wireless activity
- Repeated authentication failures

Access Point Configuration

- Use WPA3 where possible.
- Use strong enterprise authentication.
- Enable PMF.
- Keep access-point firmware updated.
- Disable obsolete wireless security protocols.
- Separate guest and internal networks.

Monitoring and Incident Response

The security team should establish alerts for abnormal management-frame activity. When an alert occurs, the team can identify the affected AP, determine whether the activity is legitimate, isolate the source where appropriate, and document the incident.

Conclusion

The five scenarios demonstrate that cybersecurity incidents commonly result from multiple weaknesses working together. Outdated software, weak authentication, insecure wireless configurations, inadequate input validation, poor session management, and insufficient monitoring can create a complete attack chain.

A successful security program should therefore combine **secure configuration, secure coding, strong authentication, network segmentation, WAF/IDS/IPS protection, wireless monitoring, vulnerability management, employee awareness, logging, and incident response**. Regular authorized security assessments using Kali Linux and other professional tools can help identify weaknesses before attackers exploit them.